

Aula 1 (Módulo 11) — Instalação e Configuração do Sysmon

1. Revisão rápida (Módulo 02, Aula 5)

Já vimos que o Sysmon é uma ferramenta gratuita e oficial da Microsoft (Sysinternals) que registra telemetria muito mais rica que os logs nativos do Windows — instalada como um serviço/driver, gravando em um log próprio (`Applications and Services Logs → Microsoft → Windows → Sysmon → Operational`). Nesta aula, instalamos e configuramos de verdade.

2. Instalação

```
# Baixar o Sysmon (link oficial da Microsoft/Sysinternals)
# https://learn.microsoft.com/sysinternals/downloads/sysmon

# Instalar com um arquivo de configuração já definido
sysmon64.exe -accepteula -i config-sysmon.xml
```

Depois de instalado, o Sysmon roda como serviço do Windows permanentemente (persistência **legítima**, no sentido que vimos no Módulo 02, Aula 3 — sobrevive a reboot, exatamente como um serviço malicioso faria, só que para fins defensivos).

```
Get-Service Sysmon64          # confirma que o serviço está rodando
sysmon64.exe -c                # mostra a configuração ATUAL carregada
```

3. O arquivo de configuração (XML)

Sem configuração, o Sysmon registraria **volume excessivo** de eventos — cada criação de processo, cada conexão, de tudo, o tempo todo. O arquivo de configuração define **o que incluir e o que excluir**, para manter o volume gerenciável e focado no que realmente importa para detecção.

```
<Sysmon schemaversion="4.90">
  <EventFiltering>
    <ProcessCreate onmatch="exclude">
      <Image condition="end with">svchost.exe</Image>
    </ProcessCreate>

    <NetworkConnect onmatch="include">
      <DestinationPort condition="is">443</DestinationPort>
      <DestinationPort condition="is">80</DestinationPort>
    </NetworkConnect>

    <FileCreate onmatch="include">
      <TargetFilename condition="contains">\Startup\</TargetFilename>
      <TargetFilename condition="end with">.exe</TargetFilename>
    </FileCreate>
  </EventFiltering>
</Sysmon>
```

`onmatch="exclude"` VS. `onmatch="include"`

- **exclude**: registra **tudo**, exceto o que combina com a regra — útil para filtrar ruído conhecido (ex.: `svchost.exe` gera volume enorme de conexões legítimas).
- **include**: registra **só** o que combina com a regra — útil quando você quer focar em algo bem específico (ex.: só conexões nas portas 80/443).

Por que importa: o equilíbrio entre volume e cobertura é uma decisão real de engenharia — configuração excessivamente ampla gera volume de log que pode sobrecarregar o SIEM (Módulo 09) e custar caro em armazenamento; configuração excessivamente restrita pode deixar passar exatamente o evento que você precisava ver. Isso é a mesma lógica de **tuning** que mencionamos no Módulo 04 (IDS/IPS) e vamos formalizar no Módulo 21 (Detection Engineering).

4. Não reinvente a roda: configurações públicas testadas

Escrever uma configuração do zero é trabalhoso e fácil de errar. A comunidade de segurança mantém configurações públicas bem testadas — a mais citada é a do projeto **SwiftOnSecurity** (uma configuração educacional, com comentários explicando cada regra) e a mais orientada a ambientes corporativos avançados é a do **Olaf Hartong (via a comunidade Neo23x0 / Sysmon-Modular)**.

Nota sobre fonte: ambas são **comunitárias** (não são documentação oficial da Microsoft), mas amplamente adotadas e referenciadas em treinamentos formais de Blue Team — é comum começar de uma dessas bases e ajustar para o seu próprio ambiente, em vez de escrever do zero.

```
# Atualizando a configuração de um Sysmon já instalado
sysmon64.exe -c nova-config.xml
```

5. Verificando que está funcionando

```
Get-WinEvent -LogName "Microsoft-Windows-Sysmon/Operational" -MaxEvents 10
```

Se aparecer eventos recentes, o Sysmon está capturando telemetria normalmente. Um exercício simples: abra o Bloco de Notas (`notepad.exe`) e confirme que um Event ID 1 (Process Creation, próxima aula) aparece nos segundos seguintes.

6. Conectando com o que já vimos

Sysmon instalado + configurado

→ grava eventos ricos (Event ID 1, 3, 7, 11, 12-14, 22 – Aula 2)

→ esses eventos alimentam:

- investigação manual local (Event Viewer, Módulo 02 Aula 4)
- EDR (Módulo 10) – em muitos produtos, Sysmon É uma das fontes de telemetria usadas
- SIEM (Módulo 09) – via agente que coleta e envia esses logs

7. Exercício prático

Se você tiver acesso a um Windows (mesmo uma VM de laboratório — lembra do Módulo 00, Aula 3):

1. Baixe o Sysmon do link oficial da Microsoft.
2. Baixe a configuração pública do SwiftOnSecurity (`sysmon-config.xml`), disponível no GitHub do projeto).
3. Instale com `sysmon64.exe -accepteula -i sysmon-config.xml`.
4. Rode `Get-WinEvent -LogName "Microsoft-Windows-Sysmon/Operational" -MaxEvents 5` e confirme que eventos estão sendo gerados.

8. Recapitulando

- Instalação: `sysmon64.exe -accepteula -i config.xml`; roda como serviço permanente.
- Configuração XML define `include` / `exclude` por tipo de evento — equilíbrio entre volume e cobertura.
- Configurações públicas testadas (SwiftOnSecurity, Sysmon-Modular) são o ponto de partida recomendado, em vez de escrever do zero.
- Sysmon alimenta tanto investigação manual local quanto EDR e SIEM.

Próxima aula (fecha o Módulo 11)

Cada Event ID relevante do Sysmon, em detalhe — com exemplo, o que investigar, e uma detecção associada para cada um.

Fontes recomendadas

- **Microsoft/Sysinternals — documentação oficial do Sysmon:** referência completa de instalação e sintaxe de configuração. <https://learn.microsoft.com/sysinternals/downloads/sysmon>
- **SwiftOnSecurity/sysmon-config (GitHub):** configuração comunitária educacional amplamente usada como ponto de partida. <https://github.com/SwiftOnSecurity/sysmon-config>